

答题骨架 Answer Flow

#	步骤	写什么
1	Framework	点名 CIA / IR·DR·BCP / Agile·Waterfall / Lifecycle ...
2	Map	题干哪句 → 框架哪一项
3	Impact	customers / employees / company 后果
4	Recommend	2 条对策 + 为何降风险

Block A · 价值与项目

Topic	背什么
Professionalism 专业主义	ethical + responsible → reliable solutions 行为: own mistakes · honest progress · client confidentiality (客户保密) 组织: onboarding · peer-feedback / mentoring
can we → should we 专业判断	Can build? → Should proceed? Risks? Who affected? 核心: professional judgement (专业判断) 看后果与责任
IT Lifecycle 八阶段	plan→analysis→design→dev→test→impl→ops→retire
跳过步骤风险	undetected requirements · technical debt (技术债) overruns lifecycle reviews (生命周期评审) → 识别 obsolescence (过时)

	Agile 敏捷	Waterfall 瀑布
结构	短迭代 iterative	线性 linear gates
变化	adapt to change	late change 成本高
风险	frequent test + client review → early detection	late integration test
干系人	持续参与 stakeholder engagement	首尾参与

	Linear 线性	Continuous 持续
发布	large infrequent releases	small frequent releases
风险	issues detected late	continuous testing 早修复
循环	Plan → Build → Deploy → Monitor → 再 Plan	

Block B · 沟通

7Cs	Clear 清楚 · Concise 简洁 · Concrete 具体 · Correct 正确 · Coherent 连贯 · Complete 完整 · Courteous 礼貌
-----	---

SBAR	写什么
S Situation 现状	现在发生什么 (短、直接)
B Background 背景	为何重要
A Assessment 评估	原因 / 影响分析
R Recommendation 建议	下一步 + 需要对方做什么

Power-Interest 权力-利益矩阵	
高 Power · 高 Interest	Manage closely 密切管理
高 Power · 低 Interest	Keep satisfied 保持满意
低 Power · 高 Interest	Keep informed 保持知情
低 Power · 低 Interest	Monitor 最低投入监控

Block B · 治理与变革

IT Governance 三问
1 做对的事? alignment 战略对齐
2 做对的方式? accountability 问责 · compliance 合规
3 拿到收益? value delivery · KPIs

COBIT	内容
EDM 治理	Evaluate · Direct · Monitor
APO Plan	Align, Plan, Organise
BAI Build	Build, Acquire, Implement
DSS Run	Deliver, Service, Support
MEA Monitor	Monitor, Evaluate, Assess

COBIT vs ITIL: COBIT = 治理定方向 alignment/control; ITIL = 服务怎么交付交付 ITSM

	Project 项目管理	Change 变革管理
focus	scope/time/cost/quality	people adoption 人员采纳
goal	deliver solution 交付方案	deliver adoption 交付采纳
success	on time/budget	员工在用、有信心、能胜任

ADKAR 个人变革	
Awareness 认知 → Desire 意愿 → Knowledge 知识 → Ability 能力 → Reinforcement 巩固	

Change states: current → transition 过渡期 (最危险) → future

Kübler-Ross: denial 否认 → anger 愤怒 → bargaining 讨价还价 → depression 抑郁 → acceptance 接受

估算 Estimation · Q7

作用	forecast time/cost/resources → schedules & budgets
不准原因	scope creep 范围蔓延 · changing requirements optimism bias 乐观偏差 · lack of historical data
方法	PERT 三点估 best/most likely/worst Delphi 专家匿名共识 expert judgement

Block E · 句库 (通用)

Agile reduces risk through frequent testing and client reviews, enabling early detection of issues.
→ 敏捷靠频繁测试与客户评审, 早发现风险

True success comes when end-users adopt the new system and integrate it into daily work.
→ 变革成功 = 用户真正采纳并日常使用

Governance sets direction (EDM), while management plans, builds, runs, and monitors (PBRM).
→ 治理定方向, 管理负责执行

Block C · 安全 Security · Q8/Q10

CIA	场景触发
C Confidentiality 保密	plain text 明文 · weak hashing 弱哈希 · XSS 偷 session
I Integrity 完整	records altered 记录被改 · exam files · SQLi 改库
A Availability 可用	peak crash 高峰宕机 · ransomware 勒索 · exam period down

漏洞 Vulnerability	典型
Human 人为 ★	weak passwords · phishing 钓鱼 · insider 内部威胁 · weakest link
Technological	unpatched 未打补丁 · misconfiguration 配置错误 · weak encryption
Organisational	no policies · poor IR planning · third-party risk
Process	excessive privileges 权限过大 · poor patch mgmt
Physical	insecure server room · theft · power failure

NIST CSF	Identify 识别 · Protect 防护 · Detect 检测 · Respond 响应 · Recover 恢复
STRIDE	Spoofing 假冒 · Tampering 篡改 · Repudiation 抵赖 · Info disclosure 泄露 · DoS 拒绝服务 · Elevation 提权

Data Lifecycle	控制点
collection 采集	minimisation 最小化 · input validation · consent 同意
storage 存储	encryption at rest 静态加密 · access control · backups
processing 处理	RBAC · audit logs 审计日志
sharing 共享	TLS/VPN · masking/anonymization 脱敏
archival 归档	retention schedules 保留策略
destruction 销毁	secure wiping · cryptographic erasure

Block C · 应急 IR/DR · Q9/Q11

IRP 阶段	Preparation → Identification → Containment 遏制 → Eradication 根除 → Recovery → Lessons learned
--------	---

计划	何时用	核心
IRP Incident Response	攻击进行中 active attack	detect · contain · eradicate · recover
DRP Disaster Recovery	系统已破坏 major outage	restore IT · RTO/RPO 恢复目标
BCP Business Continuity	业务不能停	maintain critical functions 关键业务

GDPR 核心: minimisation 最小化 · purpose limitation 目的限制 · accountability 问责 · lawfulness/transparency 合法透明

Block E · 安全句库 Q8—Q11

At its core, information security ensures confidentiality, integrity, and availability of data. → 信息安全核心是 C/I/A
Implement secure password hashing (bcrypt/PBKDF2/Argon2 + unique salts) so credentials remain protected even if the database is compromised. → 哈希+盐, 库泄露也难还原密码
Use input validation, output sanitization, and parameterized

Block D · 质量 Quality · W10/W11

概念	定位	关键词
QA 质量保证	proactive 事前 · process	prevent defects 预防缺陷
QC 质量控制	reactive 事后 · product	detect defects 发现缺陷
Testing 测试	QC 子集	verification 验证 + validation 确认

PDCA: Plan 计划 → Do 执行 → Check 检查 → Act 改进 (continuous improvement 持续改进)

Block D · 伦理 Ethics · W12

	Laws 法律	Ethics 伦理
标准	minimum 最低底线	ideal 理想 aspirational
性质	formal, enforceable 可强制执行	dynamic, contextual 依情境
依据	legal system	conscience + professional values

要点 legal compliance alone isn't enough 仅合规不够

ACS Code 六项价值
Public interest 公众利益 · Quality of life 提升生活质量 · Honesty 诚实 · Competence 胜任 · Professional development 专业发展 · Professionalism 专业精神

Ethical Models 伦理模型	判断依据
Utilitarian 功利/后果论	maximise overall good 最大化整体利益
Deontological 义务论	duties & rules 规则与义务; intent 意图
Virtue ethics 美德论	character & integrity 品格与诚信

Block E · 应急 & Impact 句库

This requires incident response to detect, contain, and investigate the active security event before damage spreads.
→ 需 IR: 检测、遏制、调查进行中事件

This requires disaster recovery to restore encrypted systems and critical services within acceptable RTO/RPO targets.
→ 需 DR: 在 RTO/RPO 内恢复系统

A formal incident response plan defines roles, escalation, containment steps, and is validated through exercises.
→ 正式 IR 计划: 角色/升级/遏制 + 演练

Maintain secure, isolated backups (offline/immutable, regularly tested) to improve recovery reliability.
→ 离线/不可变备份 + 定期测试

Customers face financial losses and loss of trust; employees bear remediation workload; the company risks reputational damage and regulatory penalties.
→ Impact 三连: 客户/员工/公司

IT professionals must place the primacy of the public interest above personal and sectional interests.
→ ACS: 公共利益优先 primacy of the public interest

QA prevents defects by improving processes; QC detects defects in deliverables; testing verifies and validates behaviour.
→ QA 防 · QC 查 · Testing 验

Closed-book exam · 闭卷仅供复习 · 详情见四组笔记 + 5990 必背速查